

PayPal Callback Phishing Email Investigation Report

Author: Nikhil Vedpathak

Project Type: Email Phishing Analysis

Date: May 2026

Introduction

While reviewing emails in my Gmail spam folder, I found a message claiming to be from PayPal. The email stated that a Bitcoin purchase worth \$418.42 USD had been processed and instructed the recipient to contact a support number if the transaction was not authorized.

At first glance, the message appeared convincing because it used PayPal branding and included transaction details, an invoice number, and a support hotline. Since phishing emails often use fear and urgency to trick users, I decided to investigate the message further.

The goal of this project was to determine whether the email was legitimate, identify phishing indicators, extract relevant IOCs, and document the findings.

Email Overview

The email claimed that a Bitcoin purchase had been successfully processed through PayPal. It stated that if the recipient did not authorize the transaction, they should immediately contact a support hotline.

Key details observed:

Item	Value
Claimed Organization	PayPal
Subject	Review Recent Activity
Transaction Amount	\$418.42 USD
Description	Bitcoin Purchase (0.0063 BTC)
Invoice Number	INV056677

Item	Value
Support Number	+1 (813) 934-5085

The message attempted to create concern by suggesting that a financial transaction had already occurred.

Initial Observations

Several warning signs were visible before even looking at the email headers.

The first indicator was the sender address. Although the email claimed to be from PayPal, the sender domain was:

Alix952577@heckmann-angeln.de

A legitimate PayPal notification would normally originate from an official PayPal-controlled domain.

Another observation was the generic greeting:

"Dear Valued Customer"

Most legitimate financial institutions typically address customers by name.

The message also relied heavily on urgency and instructed the recipient to contact a support number immediately if the transaction was not recognized.

Header Investigation

After obtaining the original email headers, I reviewed the delivery path and sender information.

The message was sent from:

Alix952577@heckmann-angeln.de

The email passed SPF validation. However, this does not mean the email was legitimate. SPF only confirms that the sender was authorized to send email on behalf of their own domain.

The investigation showed that the attacker controlled the sending domain and used properly configured mail infrastructure.

Infrastructure identified during analysis:

Type	Value
Domain	heckmann-angeln.de
Mail Server	mail.alfi.cloud
Sending IP	65.108.225.10
Originating IP	216.73.162.151

This indicates that the email was sent using a real email account rather than simple sender spoofing.

Email Content Analysis

The email was professionally formatted and visually resembled a payment notification.

During analysis, I found that the email did not contain:

- Malware attachments
- Executable files
- Office documents
- External download links

Instead, the primary action requested by the attacker was to call a phone number.

The HTML source revealed the following telephone link:

tel:+18139345085

This means that clicking the button would open the device dialer and prepare a call to the provided number.

This technique is commonly used in callback phishing campaigns.

Social Engineering Techniques

The success of this attack relies more on psychological manipulation than technical exploitation.

Fear

The email informed the recipient that a Bitcoin purchase had already been completed.

Because many users do not regularly buy cryptocurrency, this immediately creates concern and confusion.

Urgency

The message encouraged immediate action and suggested that account review could occur if the transaction was not verified.

This pressure is intended to reduce critical thinking and encourage quick decisions.

Trust and Brand Impersonation

The attacker used PayPal branding and professional formatting to increase credibility.

Many users are more likely to trust an email that appears to come from a familiar company.

Phone-Based Manipulation

Rather than directing users to a website, the attacker wanted victims to call a support number.

Once on the phone, scammers often attempt to:

- Gain trust
- Collect personal information
- Request banking details
- Convince victims to install remote access software
- Facilitate fraudulent transactions

Indicators of Compromise (IOCs)

Email Indicators

Sender:

Alix952577@heckmann-angeln.de

Subject:

Review Recent Activity

Infrastructure Indicators

Domain:

heckmann-angeln.de

Mail Server:

mail.alfi.cloud

Sending IP:

65.108.225.10

Originating IP:

216.73.162.151

Phone Number

+1 (813) 934-5085

Invoice Reference

INV056677

MITRE ATT&CK Mapping

Technique ID	Technique
T1566.001	Phishing
T1204	User Execution
T1598	Phishing for Information

Risk Assessment

Category	Assessment
Malware Risk	Low
Credential Theft Risk	Medium
Social Engineering Risk	High
Financial Fraud Risk	High
Overall Severity	High

Although the email did not contain malware, it presented a significant risk because it attempted to manipulate the recipient into contacting a scam operator.

Lessons Learned

This investigation highlighted several important phishing indicators:

- Always verify the sender domain.
- Do not trust branding alone.
- Be cautious of unexpected financial transactions.
- Avoid calling phone numbers provided in suspicious emails.
- Review email headers when legitimacy is uncertain.
- Verify account activity through official applications and websites.

Even well-designed phishing emails often reveal signs of fraud when examined carefully.

Conclusion

Based on the findings, the email was identified as a PayPal-themed callback phishing attempt.

The sender address was not associated with PayPal, the transaction was fabricated, and the main objective was to convince the recipient to call a fraudulent support number.

No malware or malicious attachments were found. Instead, the attack relied entirely on social engineering techniques such as fear, urgency, and brand impersonation.

This project provided practical experience in phishing analysis, email header investigation, IOC extraction, and threat documentation. It also demonstrated how attackers can create convincing messages that appear legitimate while attempting to manipulate users into taking unsafe actions.

Skills Demonstrated

- Email Header Analysis
- Phishing Detection
- IOC Extraction
- Social Engineering Analysis
- Threat Intelligence
- Security Investigation
- Technical Documentation
- MITRE ATT&CK Mapping